



DanglingTree Enterprise

Internal Security Assessment Authorization & Rules of Engagement

CONFIDENTIAL — RESTRICTED DISTRIBUTION

Document Type:	Penetration Testing Authorization & Rules of Engagement
Target Organization:	DanglingTree Enterprise
Target Domain:	danglingtree.htb
Classification:	CONFIDENTIAL — INTERNAL USE ONLY
Document Version:	1.0
Prepared By:	Security Assessment Team
Issue Date:	_____
Review Date:	_____

WARNING: This document contains sensitive security information pertaining to DanglingTree Enterprise internal infrastructure. Unauthorized access, reproduction, or distribution of this document is strictly prohibited and may result in legal action.

CONTENTS

Table of Contents

1	Executive Summary	
2	Scope of Engagement	
3	Provided Credentials	
4	Rules of Engagement	
5	Objectives	
6	Logging & Monitoring Notice	
7	Risk & Legal Disclaimer	
8	Engagement Timeline	
9	Authorization & Signatures	

SECTION 1

Executive Summary

DanglingTree Enterprise has formally commissioned an internal penetration test of its Active Directory environment and associated network infrastructure. The primary motivation for this engagement is to conduct a comprehensive evaluation of the organization's current security posture, identify exploitable vulnerabilities within the internal domain, and assess the effectiveness of existing defensive controls against realistic adversarial attack techniques.

This assessment is intended to simulate the activities of a malicious insider or an attacker who has obtained a foothold within the corporate network using low-privileged domain credentials. The engagement will evaluate the organization's resilience against privilege escalation, lateral movement, and misconfiguration exploitation — attack vectors commonly leveraged in real-world intrusions targeting enterprise Active Directory environments.

All activities conducted during this assessment are explicitly authorized by DanglingTree Enterprise leadership and the Information Security team. Findings produced as a result of this engagement will be documented in a formal report and delivered to the Security Team Lead and relevant stakeholders to inform remediation planning and strategic security investment decisions.

SECTION 2

Scope of Engagement

The scope of this engagement is limited exclusively to the systems, services, and network segments enumerated below. Any activity targeting systems or infrastructure outside this defined scope is strictly prohibited and may constitute unauthorized access under applicable law.

2.1 In-Scope Systems & Services

Primary Domain	danglingtree.htb
Domain Controller	dc.danglingtree.htb
Assessment Type	Internal Network / Active Directory Assessment
Target Environment	Windows Active Directory Domain
Access Vector	Authenticated — Low-privileged domain user
Network Segment	Internal corporate network (AD-integrated)

2.2 In-Scope Services & Protocols

The following protocols and services are in scope for enumeration and exploitation attempts, subject to the restrictions defined in Section 4:

- LDAP / LDAPS (TCP 389/636) — Directory enumeration and AD object analysis
- SMB (TCP 445) — File share and relay attack assessment
- Kerberos (TCP/UDP 88) — Authentication protocol exploitation (AS-REP Roasting, Kerberoasting)

- WinRM (TCP 5985/5986) — Remote management access evaluation
- RPC / MSRPC — Remote Procedure Call enumeration
- DNS (TCP/UDP 53) — Internal DNS zone and record enumeration
- Management interfaces accessible within the internal network

2.3 Out-of-Scope Systems

The following are explicitly OUT OF SCOPE. Interaction without prior written approval is a violation of this authorization: ■ Any system or IP address not belonging to danglingtree.htb ■ Production databases containing real customer or employee data ■ Third-party SaaS platforms or external cloud infrastructure ■ Any system not reachable from the authorized access point

SECTION 3

Provided Credentials

The following credentials have been formally provisioned by DanglingTree Enterprise for the exclusive use of the authorized penetration testing team during the assessment window. These credentials simulate the scenario of a compromised standard domain user account — representative of an attacker who has obtained initial access through phishing, credential stuffing, or a similar initial compromise vector.

Domain	danglingtree.htb
Username	anderson.w
Password	R3dT3am@Acc3ss#01
Account Type	Standard Domain User (Low-Privileged)
Access Level	Authenticated domain user — no elevated rights
Simulation Scenario	Compromised employee / insider threat simulation

IMPORTANT: These credentials are provided solely for this authorized security assessment. They must not be stored beyond the engagement window, shared with unauthorized parties, or used for any purpose outside the defined scope. Misuse constitutes unauthorized access and may result in immediate termination of the engagement and legal action.

SECTION 4

Rules of Engagement

The Rules of Engagement (RoE) establish the operational boundaries within which the penetration testing team must conduct all assessment activities. Adherence to these rules is mandatory. Any deviation requires prior written approval from the DanglingTree Enterprise Security Team Lead. Violations will result in immediate suspension of the engagement.

4.1 Permitted Activities

✓ ALLOWED ACTIVITIES

- Active Directory enumeration via LDAP, LDAPS, and Kerberos protocols
- SMB enumeration including share discovery, null session testing, and relay attack simulation
- Kerberoasting and AS-REP Roasting attacks against domain service accounts
- BloodHound / SharpHound data collection for attack path analysis

■ Privilege escalation attempts against identified misconfigurations and vulnerabilities
■ Lateral movement simulation using valid credentials obtained during the assessment
■ Pass-the-Hash (PtH) and Pass-the-Ticket (PtT) techniques within defined scope
■ ACL / DACL abuse exploitation (WriteDACL, GenericAll, GenericWrite, etc.)
■ Group Policy Object (GPO) misconfiguration analysis
■ Service account and delegation abuse (Unconstrained, Constrained, RBCD)
■ WinRM, RPC, and SMB-based remote execution using obtained credentials
■ DNS enumeration and zone transfer testing
■ Misconfiguration discovery across AD objects, services, and network interfaces

4.2 Prohibited Activities

X PROHIBITED ACTIVITIES
X Denial of Service (DoS) or Distributed Denial of Service (DDoS) attacks of any kind
X Intentional destruction, modification, or corruption of any data or system configuration
X Deployment of persistent backdoors, malware, rootkits, or remote access trojans (RATs)
X Disruption of production services, business operations, or live user sessions
X Exfiltration of real business data, customer records, or personally identifiable information (PII)
X Exploitation of vulnerabilities on out-of-scope systems or infrastructure
X Social engineering, phishing, or vishing of DanglingTree Enterprise employees
X Physical security testing or on-site intrusion activities
X Performing actions that could cause irreversible system damage or data loss
X Sharing or publishing credentials or findings outside the authorized testing team

4.3 Operational Conduct

The penetration testing team is required to maintain detailed operational logs of all activities, commands executed, and artifacts generated throughout the engagement. Any unexpected or unintended impact on systems must be reported immediately to the designated point of contact. The assessment team is expected to

operate with professional discretion and minimize unnecessary impact on the production environment at all times.

SECTION 5

Objectives

The engagement is structured around the following primary security assessment objectives. Each objective evaluates a specific dimension of the organization's Active Directory security posture and internal network defenses.

OBJ-01	Privilege Escalation Path Analysis
	Identify and validate all viable privilege escalation paths from the provided low-privileged domain user (anderson.w) to Domain Administrator or equivalent high-privilege accounts. Document each vector with supporting evidence.
OBJ-02	Active Directory Misconfiguration Discovery
	Enumerate and assess all accessible AD objects for exploitable misconfigurations including: overly permissive ACLs/DACLs, dangerous GPO configurations, Kerberos delegation settings, and SPN exposure.
OBJ-03	Service & Protocol Exposure Evaluation
	Assess the security configuration of core services including WinRM, SMB, RPC, and administrative interfaces. Identify services that expose the organization to lateral movement or remote code execution risk.
OBJ-04	Credential Security Assessment
	Evaluate domain credential security including password policy enforcement, account lockout configuration, Kerberoastable accounts, AS-REP roastable accounts, and plaintext credential exposure in accessible shares or scripts.
OBJ-05	Lateral Movement Simulation
	Simulate realistic lateral movement scenarios using Pass-the-Hash, Pass-the-Ticket, and credential relay attacks to assess the organization's ability to detect and contain an attacker moving within the internal network.
OBJ-06	Attack Path Visualization
	Produce a comprehensive attack path map (via BloodHound or equivalent) illustrating all identified paths from low-privileged access to Domain Admin compromise, enabling the security team to prioritize remediation efforts.

SECTION 6

Logging & Monitoring Notice

All activities performed during this security assessment are subject to active monitoring and comprehensive logging by DanglingTree Enterprise's internal security infrastructure. This includes, but is not limited to, the following monitoring capabilities:

- Windows Event Log collection across domain-joined endpoints and the Domain Controller
- Active Directory audit logging for authentication events, object modifications, and privilege use
- Network traffic capture and inspection at critical network segments
- Endpoint Detection & Response (EDR) telemetry from deployed agents
- SIEM correlation and alerting based on behavioral anomaly detection
- Kerberos ticket issuance and authentication event monitoring
- SMB session and file access audit logging

The penetration testing team must operate under the assumption of full blue team visibility at all times. The engagement may optionally be conducted as a Purple Team exercise at the discretion of the Security Team Lead, in which case coordinated detection validation may be incorporated into the assessment scope.

NOTICE: The existence of monitoring capabilities does not constitute consent for activities outside the defined scope. All actions outside scope remain unauthorized regardless of whether they are detected or not.

SECTION 7

Risk & Legal Disclaimer

This penetration test is an explicitly authorized security assessment conducted under formal written authorization of DanglingTree Enterprise. All parties involved have acknowledged and agreed to the following terms prior to commencement of any testing activities:

Authorization	This engagement is sanctioned by DanglingTree Enterprise and is conducted in full compliance with applicable laws and organizational policies. Written authorization has been obtained from designated corporate officers prior to any testing activity.
Scope Compliance	All assessment activities must remain strictly within defined scope boundaries. Any action targeting systems, services, or data outside the approved scope is explicitly unauthorized and may constitute a criminal offense under applicable computer crime legislation.

Confidentiality	All findings, credentials, vulnerabilities, and information obtained during this engagement are strictly confidential. This information must not be disclosed to unauthorized parties and must be handled in accordance with DanglingTree Enterprise's data classification policies.
No Guarantees	Completion of this assessment does not guarantee the absence of additional vulnerabilities beyond those identified. The scope, duration, and access level inherently limit the coverage achievable during a time-boxed engagement.
Indemnification	DanglingTree Enterprise indemnifies the authorized testing team against legal claims arising from in-scope activities conducted in accordance with this document, provided all rules of engagement have been followed.
Reporting Obligation	The testing team must promptly report any discovery of critical severity findings — particularly those posing immediate risk to production systems — to the designated point of contact, regardless of engagement phase.

SECTION 8

Engagement Timeline

The following table defines the scheduled timeline for this penetration testing engagement. All dates must be confirmed and signed off by the Security Team Lead prior to commencement. Changes to the engagement timeline require written approval from both parties.

Phase	Activity	Start Date	End Date	Owner
Pre-Engagement	Kickoff meeting, credential delivery, environment validation			Joint
Reconnaissance	Passive and active information gathering, DNS & LDAP enumeration			Red Team
Exploitation	Vulnerability exploitation, privilege escalation, lateral movement			Red Team
Post-Exploitation	Domain Admin confirmation, attack path documentation			Red Team
Reporting	Finding consolidation, report drafting, risk scoring			Red Team
Debrief	Findings presentation, remediation discussion, Q&A			Joint
Remediation Review	Optional re-test of remediated critical findings			Joint

SECTION 9

Authorization & Signatures

By signing below, the authorized representatives of DanglingTree Enterprise confirm that they have read, understood, and formally approved this Internal Security Assessment Authorization and Rules of Engagement document. The signatures below constitute binding authorization for the penetration testing team to conduct the activities described herein, subject to all conditions and restrictions set forth in this document.

Authorized By	Reviewed By	Date
Security Team Lead	IT Director / CISO	DD / MM / YYYY
DanglingTree Enterprise	DanglingTree Enterprise	

Additional Authorized Representative (if applicable):

Name / Title	Signature	Date
--------------	-----------	------

-------	-------	----------------

*This document is classified CONFIDENTIAL and constitutes a legally binding authorization for the security assessment activities described herein. Unauthorized reproduction or distribution is strictly prohibited. ©
DanglingTree Enterprise — Internal Security Division*